

AVANCE DE PROYECTO INTEGRADOR

Creación de Políticas de Seguridad

Nombre del alumno:	Luis Alberto Vargas Gonzalez
--------------------	------------------------------

I. Políticas de seguridad de software

1. Política de Protección de Endpoints (Antivirus Corporativo)

- **Alcance:** Todos los equipos de cómputo (estaciones de trabajo y laptops) que utilicen el sistema operativo Windows dentro de la red corporativa y plantas ensambladoras.
- **Descripción:** Queda estrictamente prohibido el uso de versiones de antivirus gratuitas o domésticas. El departamento de TI debe instalar y mantener una solución de antivirus de grado empresarial (EDR) en el 100% de los equipos para garantizar la detección proactiva de amenazas.
- **Relación con vulnerabilidad:** Sustituye el antivirus gratuito actual que no ofrece protección suficiente para una empresa de este nivel.

2. Política de Gestión de Actualizaciones de Sistemas Operativos

- **Alcance:** Todos los 15,000 equipos personales (Windows y macOS) asignados a los empleados en las plantas y el centro de diseño.
- **Descripción:** Se establece un calendario obligatorio de actualizaciones mensuales. Los sistemas operativos deben configurarse para descargar e instalar parches críticos de seguridad de forma automática en un periodo no mayor a 7 días tras su liberación.
- **Relación con vulnerabilidad:** Resuelve la falta de un proceso para que los empleados mantengan actualizados sus sistemas.



3. Política de Mantenimiento y Parches de Bases de Datos

- **Alcance:** Todos los motores de bases de datos (DB2, Oracle y SQL Server) que operan en los sites de la empresa.
- **Descripción:** Todo motor de base de datos debe contar con soporte vigente del fabricante y estar actualizado a una versión no mayor a 12 meses de antigüedad. Es obligatorio aplicar parches de seguridad trimestralmente para mitigar riesgos de inyección o fuga de datos.
- **Relación con vulnerabilidad:** Atiende el rezago de 3 años sin actualizaciones ni parches en las bases de datos críticas.

4. Política de Control de Instalación de Software de Terceros

- **Alcance:** Toda la plantilla de empleados con acceso a equipos informáticos de la organización.
- **Descripción:** Los empleados tienen prohibido descargar o instalar cualquier tipo de software proveniente de internet sin la autorización previa y revisión de seguridad del departamento de TI. El acceso administrativo a los equipos se limitará para evitar instalaciones no autorizadas.
- **Relación con vulnerabilidad:** Mitiga el riesgo de introducir *malware* o *adware* por la instalación libre de software de internet.

5. Política de Gestión y Auditoría de Licencias de Software

- **Alcance:** Departamento de TI y área de Compras.
- **Descripción:** Se debe implementar un sistema de Gestión de Activos de Software (SAM) para rastrear la compra, asignación y vigencia de todas las licencias. Queda prohibida la compra "a granel" sin un control individualizado de derechos de uso por equipo.
- **Relación con vulnerabilidad:** Corrige la falta de administración de licencias compradas a granel y asegura el cumplimiento legal de la empresa.



II. Políticas de seguridad de hardware

6. Política de Ciclo de Vida y Actualización de Infraestructura de Red

- **Alcance:** Todos los equipos de comunicaciones (routers, switches y firewalls Cisco) en las tres plantas y el centro de diseño.
- **Descripción:** Se establece que ningún equipo de red podrá operar con una antigüedad mayor a 5 años sin un plan de renovación vigente. Es obligatorio que el equipo de TI realice actualizaciones de firmware y parches de seguridad de manera semestral para asegurar el soporte del fabricante.
- **Relación con vulnerabilidad:** Ataca directamente la obsolescencia de 5 años del equipo Cisco y la falta de actualizaciones que comprometen la estabilidad de la red.

7. Política de Mantenimiento Preventivo de Servidores y Mainframes

- **Alcance:** Los 30 servidores Windows, 15 Unix (AIX) y los 3 mainframes de la organización.
- **Descripción:** El departamento de TI debe programar ventanas de mantenimiento preventivo mensual que no excedan las 4 horas de inactividad. Se prohíben los mantenimientos prolongados de 2 días que afecten la disponibilidad, debiendo implementar esquemas de alta disponibilidad para evitar cortes en el servicio.
- **Relación con vulnerabilidad:** Reduce los tiempos excesivos de mantenimiento (de 8 horas a 2 días) y mejora la disponibilidad operativa de los sites.



8. Política de Inventario y Control de Activos Informáticos

- **Alcance:** Todo el hardware propiedad de la empresa, incluyendo servidores, estaciones de trabajo y periféricos.
- **Descripción:** Se debe mantener un inventario digitalizado y actualizado en tiempo real de todos los activos, incluyendo número de serie, ubicación, usuario asignado e historial de cambios. Queda prohibida la conexión a la red de cualquier equipo que no esté debidamente etiquetado y registrado en el inventario oficial.
- **Relación con vulnerabilidad:** Resuelve la inexistencia de un inventario de activos y el nulo control de cambios o mantenimiento.

9. Política de Sustitución y Renovación Tecnológica

- **Alcance:** Equipos de cómputo personales (10,000 Windows y 5,000 macOS) y servidores.
- **Descripción:** La sustitución de equipos se realizará con base en su ciclo de vida útil (máximo 4 años para laptops y 5 para servidores) y no únicamente en situaciones de emergencia. Cada cambio debe quedar documentado en el historial de mantenimiento del activo.
- **Relación con vulnerabilidad:** Elimina la mala práctica de cambiar equipos solo en caso de emergencia, lo que pone en riesgo la productividad del empleado.

10. Política de Integridad Física de los Equipos de Cómputo

- **Alcance:** Todo el personal que tenga asignado un equipo informático o acceso a los sites.
- **Descripción:** Queda estrictamente prohibida la apertura, modificación física o sustracción de componentes internos de los equipos sin la supervisión del área de TI. Cualquier reparación o cambio de hardware debe registrarse en una bitácora de mantenimiento centralizada para evitar la introducción de dispositivos infectados o la pérdida de partes.
- **Relación con vulnerabilidad:** Como bien se comentó antes, esta política previene la sustracción de partes y la introducción de hardware ajeno infectado ante la falta de controles actuales.



III. Políticas de información confidencial

11. Política de Control de Acceso Basado en Roles (RBAC)

- **Alcance:** Todos los sistemas informáticos, bases de datos y aplicaciones de la empresa.
- **Descripción:** Se elimina el acceso total (*full access*) generalizado. El acceso a la información se otorgará bajo el "principio de menor privilegio", donde cada empleado tendrá permisos exclusivamente para los datos necesarios según su función laboral, previa autorización del jefe de área.
- **Relación con vulnerabilidad:** Mitiga el riesgo de que cualquier empleado modifique o elimine información crítica de manera no autorizada.

12. Política de Clasificación de la Información

- **Alcance:** Toda la información generada, procesada o almacenada por la organización, incluyendo diseños automotrices y datos multimedia.
- **Descripción:** Se establecen cuatro niveles de clasificación: Pública, Uso Interno, Confidencial y Restringida. Toda la información debe ser etiquetada según su sensibilidad y solo los niveles "Confidencial" y "Restringida" requerirán controles de cifrado y auditoría estricta.
- **Relación con vulnerabilidad:** Resuelve la falta total de clasificación y control de datos mencionada en el caso.



13. Política de Seguridad para el Acceso Remoto (VPN)

- **Alcance:** Empleados que requieran conexión a los sistemas desde fuera de las instalaciones físicas.
- **Descripción:** Es obligatorio el uso de una red privada virtual (VPN) con cifrado de grado industrial y autenticación de dos factores (2FA) para cualquier conexión remota. Se prohíbe el uso de conexiones directas o protocolos no cifrados hacia la red interna.
- **Relación con vulnerabilidad:** Cubre la carencia de un proveedor de servicios de VPN y la falta de métodos de conexión remota seguros.

14. Política de Cifrado y Protección de Bases de Datos

- **Alcance:** Motores de bases de datos DB2, Oracle y SQL Server en todos los sites.
- **Descripción:** Toda información sensible, especialmente la propiedad intelectual del centro de diseño, debe estar cifrada tanto en reposo (dentro de la base de datos) como en tránsito (en la red). Se deben implementar mecanismos de integridad para asegurar que los registros no sean alterados sin dejar rastro.
- **Relación con vulnerabilidad:** Protege los datos críticos almacenados en bases de datos que actualmente no reciben parches de seguridad ni tienen controles de integridad.

15. Política de Respaldos de Información Crítica

- **Alcance:** Servidores, mainframes y bases de datos que contienen información vital para la manufactura y el diseño.
- **Descripción:** La empresa debe garantizar el respaldo del 100% de la información crítica de manera diaria. Se debe implementar un esquema de almacenamiento que asegure que siempre haya espacio suficiente para los respaldos y que existan copias fuera de sitio (*off-site*) para recuperación en caso de desastre.
- **Relación con vulnerabilidad:** Corrige la deficiencia actual donde solo se puede respaldar una cuarta parte de la información por falta de espacio.



IV. Políticas ambientales

16. Política de Respuesta ante Sismos y Desastres Naturales

- **Alcance:** Todo el personal y visitantes del centro de diseño ubicado en Múnich.
- **Descripción:** Es obligatorio establecer un Plan de Continuidad del Negocio (BCP) que incluya rutas de evacuación señalizadas, puntos de reunión seguros y la realización de simulacros trimestrales para asegurar la integridad física de los empleados en zonas de alto riesgo sísmico.
- **Relación con vulnerabilidad:** Mitiga el riesgo de fatalidades y pérdida de personal ante la falta de un plan claro de evacuación en el centro de diseño.

17. Política de Vigilancia y Monitoreo Físico (CCTV)

- **Alcance:** Todas las áreas comunes, entradas, salidas y perímetros de las plantas ensambladoras y oficinas administrativas.
- **Descripción:** El departamento de Seguridad Física debe asegurar que el 100% de las cámaras de seguridad estén operativas y graben de forma continua. Se debe realizar una revisión técnica quincenal para garantizar que no existan puntos ciegos o cámaras dañadas.
- **Relación con vulnerabilidad:** Corrige la inoperatividad de las cámaras actuales que favorece el ingreso de personas no autorizadas.



18. Política de Gestión de Residuos de Manufactura y Electrónicos

- **Alcance:** Áreas de producción, laboratorios de hardware y oficinas administrativas.
- **Descripción:** Se debe implementar un programa de clasificación y disposición final de desechos generados en la manufactura automotriz. Los residuos electrónicos (hardware obsoleto) deben ser destruidos o reciclados mediante proveedores certificados para evitar la fuga de información sensible contenida en componentes físicos.
- **Relación con vulnerabilidad:** Resuelve la falta de control de desechos generados por el proceso de manufactura en las oficinas.

19. Política de Seguridad Física en Centros de Datos (Sites)

- **Alcance:** Los tres sites de servidores ubicados en las plantas ensambladoras.
- **Descripción:** El acceso a las salas de servidores y mainframes está restringido únicamente al personal de TI autorizado. Los sistemas de enfriamiento, detección de incendios y suministro de energía ininterrumpida (UPS) deben ser inspeccionados mensualmente para prevenir fallas por factores ambientales.
- **Relación con vulnerabilidad:** Asegura la protección de los mainframes y servidores ante fallas ambientales o accesos físicos indebidos.

20. Política de Protección de Activos en Tránsito y Exterior

- **Alcance:** Equipo de hardware automotriz premium en fase de desarrollo y prototipado.
- **Descripción:** Todo hardware en desarrollo que deba ser trasladado entre plantas debe contar con un registro de custodia y protección contra factores ambientales (humedad, calor extremo). Queda prohibido dejar prototipos o hardware sensible en áreas no resguardadas del centro de diseño.
- **Relación con vulnerabilidad:** Protege el hardware premium y deportivo contra daños ambientales o robos físicos por falta de controles de activos.



V. Políticas de RH

21. Política de Control de Visitantes e Invitados

- **Alcance:** Todas las instalaciones de la empresa, incluyendo las 3 plantas ensambladoras y el centro de diseño.
- **Descripción:** Todo visitante debe registrarse obligatoriamente en la recepción, portar un gafete de identificación visible y estar acompañado por un empleado responsable en todo momento. Queda estrictamente prohibido el ingreso de invitados a áreas críticas como los sites de servidores o laboratorios de desarrollo sin autorización escrita de la gerencia.
- **Relación con vulnerabilidad:** Elimina la práctica actual de permitir invitados sin restricciones debido a la falla en cámaras y falta de control físico.

22. Política de Concientización y Capacitación en Ciberseguridad

- **Alcance:** Los 35,000 empleados de la organización a nivel mundial.
- **Descripción:** Es obligatorio que todo el personal participe en sesiones de capacitación trimestrales sobre seguridad de la información, enfocadas en la detección de malware, ingeniería social y el uso correcto de los sistemas institucionales. La capacitación se evaluará y será requisito para mantener los privilegios de acceso al sistema.
- **Relación con vulnerabilidad:** Ataca la apatía del usuario y el desconocimiento que permite la instalación de software malicioso y el mal manejo de los activos.



23. Política de Uso Aceptable de Activos Tecnológicos

- **Alcance:** Empleados con equipos asignados (Windows y macOS) y personal de desarrollo multimedia (Java e iOS).
- **Descripción:** Los equipos informáticos son propiedad exclusiva de la empresa y deben utilizarse únicamente para fines laborales. El incumplimiento de las políticas de seguridad, como la descarga de software no autorizado, será motivo de sanciones disciplinarias de acuerdo con el reglamento interno de trabajo.
- **Relación con vulnerabilidad:** Establece consecuencias legales y administrativas ante la instalación libre de software de internet sin permiso.

24. Política de Confidencialidad y Acuerdos de No Divulgación (NDA)

- **Alcance:** Todo el personal interno, contratistas y proveedores externos de la empresa.
- **Descripción:** Es requisito indispensable la firma de un acuerdo de confidencialidad al momento de la contratación. Este acuerdo obliga al empleado a proteger los secretos industriales de la tecnología automotriz premium y deportiva, incluso después de terminar su relación laboral con la empresa.
- **Relación con vulnerabilidad:** Protege la propiedad intelectual en un entorno donde no existen jerarquías de acceso ni roles definidos.

25. Política de Revocación de Accesos por Baja de Personal

- **Alcance:** Departamentos de Recursos Humanos y Tecnologías de la Información.
- **Descripción:** Ante la terminación de un contrato laboral, el área de RH debe notificar de inmediato a TI para la revocación total de accesos lógicos (cuentas, correos, VPN) y la recuperación del gafete de proximidad en un plazo no mayor a 2 horas. Se debe realizar una auditoría final del equipo asignado antes de su reingreso al inventario.
- **Relación con vulnerabilidad:** Asegura que los privilegios de "full access" sean eliminados oportunamente para evitar accesos no autorizados post-empleo.

